

EXP, progression and personalized practice

SENTRI cybersecurity awareness course | Version 1.1 | 10 September 2026

Design status: Proposed architecture for discussion and implementation planning. This document does not claim that these rules are implemented in the application. Numerical weights, thresholds and time estimates require pilot validation.

The agreed direction

Use a company-configurable case plan, a fixed display target of **1,000 EXP = 100%**, and attempt limits of **3 / 2 / 2 / 1**. There is no fixed per-email BaseEXP. Each planned learning slot receives a share of its phase budget. Personalization adapts future case selection to demonstrated learning needs.

Measure	What it means
Phishing Score (PS)	A heuristic description of phishing-related indicators in a case. It is not ground truth, probability or measured difficulty.
Personalized weights	The relative training priority of tags for an individual employee.
Performance	How well the employee answered a particular submission.
EXP	The earned share of a course reward budget.
Progress and assessment	EXP progress toward 100%, plus independent coverage and assessment checks.

System at a glance

Company course plan
↓
Player profile + required coverage → select approved cases
↓
Freeze assignment rules and slot rewards
↓
Investigate → submit → score → feedback / retry
↓
Finalize EXP + skill evidence → next case or recovery

Scope: formulas are fully specified for Email Investigation. Password Review, Data Classification and future activities need their own observable rubrics; they do not need an artificial phishing score.

Course planning and phases

Company configuration controls the learning plan. Employee rank changes context and authority; observed skill informs practice difficulty.

Phase	EXP range / budget	Submissions	Typical experience
Easy	0-250 / 250	3	Clear evidence, introductory guidance
Normal	250-500 / 250	2	Mixed evidence, less guidance
Hard	500-750 / 250	2	Subtle evidence, realistic workplace context
Master	750-1,000 / 250	1	Fresh assessment cases; no corrective hints before submission

Exact boundaries: 250 EXP plus completed Easy requirements unlocks Normal; 500 unlocks Hard; 750 unlocks Master. Reaching 1,000 EXP alone does not bypass coverage or final-assessment requirements.

Company chooses

Target duration, required topics, audience, permitted reference materials, assessment coverage, and recovery allowance. SENTRI translates these into a feasible number of learning slots. A slot is an assigned learning objective with a fixed reward allocation; a replacement case can assess the same objective.

Planning preset	Estimated time	Purpose
Refresher	10-15 minutes	A narrow set of previously covered objectives
Standard	About 30 minutes	Core awareness with relevant workplace cases
Extended	45-60 minutes	Broader coverage and additional practice

These are product-planning estimates, not industry requirements or guaranteed completion times. A short refresher may have too few cases to infer reliable per-tag skill scores. Show insufficient evidence rather than inventing mastery.

The time-budget rule

Role-relevant cases replace planned cases. Budget for reading, feedback, retries and generation latency as well as successful responses. A useful planning estimate is:

$$T_{\text{plan}} = T_{\text{onboarding}} + \text{SUM}(T_{\text{slot_expected}}) + T_{\text{summary}} + T_{\text{recovery_allowance}}$$

If required topics cannot fit the selected duration, show the minimum feasible estimate. If the company requires a hard stop, end with a follow-up status when necessary; do not silently mark an incomplete learner as graduated.

Plan stability

Version the course template and freeze the employee enrollment. Changes apply to new enrollments unless an explicit migration is chosen. This prevents an administrator edit from unexpectedly changing someone's target.

Behavior tags and weights

Keep the seven behavior tags from the task-system diagram. They describe persuasion present in a scenario, not personality traits.

Tag / identifier	Base weight	Interpretation
Authority authority	10	Claimed power, seniority or expertise
Urgency urgency	10	Pressure to act quickly
Fear fear	8	Threat of a negative outcome
Curiosity curiosity	6	Temptation to discover hidden information
Reward / Incentive rewardIncentive	8	Promise of a benefit
Helpfulness helpfulness	6	Appeal to assist someone
Familiarity / Impersonation familiarityImpersonation	9	Apparent known identity or relationship
Total	57	Fixed catalog denominator for this version

Weights retain the original values except the proposed merged Familiarity / Impersonation weight: Trust 5 + Familiarity 4 = 9. Scarcity and Reciprocity are no longer separate buckets. The merge is an authoring decision, not a validated effect size.

Intensity b	Bucket	Meaning
0	Absent	Not present
0.25	Background	Minor element
0.50	Supporting	Moderate influence
0.75	Strong	Prominent influence
1.00	Central	The scenario depends heavily on this influence

$$B = \text{SUM}(b_i * w0_i) / 57$$

Weight is shared baseline importance. Intensity is how strongly this case uses the trigger. Urgency 0.75 with base weight 10 contributes 7.5 to the numerator. Ordinary deadlines and legitimate authority can also appear in genuine messages.

Choose one primary behavior tag for initial player-profile updates; secondary tags support content variety. Cases with no meaningful trigger have no primary behavior update. Do not count one wrong answer as seven independent weaknesses.

Knowledge taxonomy

Use skill buckets for observable abilities. Only a subset of their associated risk indicators contributes to the case Phishing Score.

Group	Skill tags	Observable competency
Message and request assessment	senderIdentity linkDestination attachmentSafety requestContext	Check sender claims, destinations, file handling, and whether the request fits the business context.
Verification and response	independentVerification authorizationChecks incidentReporting	Use an established channel, check entitlement and approval, and report appropriately.
Account protection	credentialProtection mfaSafety passwordStrength passwordUniqueness	Protect secrets, handle authentication requests safely, and evaluate password strength and reuse.
Information protection	dataClassification sensitiveDataHandling sharingPermissions	Apply labels and choose appropriate storage, transfer, disclosure, permissions and retention.

How these replace the older list

Remove "email" as a knowledge tag because it is a task type. Absorb sender spoofing into senderIdentity and destination-domain inspection into linkDestination. Keep the two scopes distinct. General social engineering belongs in the specific behavior tags. Financial verification uses independentVerification and authorizationChecks.

Assessment weights are local to a case

Assign two to four genuinely assessed knowledge tags per case. Map each rubric check to its primary skill. Begin with equal weights of 1 for independent checks; use weight 2 only for a documented stronger emphasis. Mandatory safety requirements remain pass gates regardless of points.

Do not count duplicate questions as independent evidence. Alternative valid reasoning paths need equivalent rubrics. A topic mentioned in an email is not automatically assessed. The existing six investigation panels are UI categories and need not match the skill taxonomy one-to-one.

Three different quantities:

Knowledge tag = the skill being tested.

Case indicator intensity = evidence of risk in this email.

Player skill score = observed performance on mapped checks.

Password strength, incident reporting and similar skills do not directly make an email suspicious. They remain learning objectives even when they have no term in the Phishing Score formula.

Phishing Score calculation

Retain the original 40% behavior / 60% knowledge-indicator structure. Ground truth remains a separate approved answer.

Knowledge-linked case indicator	Maps to	Weight v0
Sender identity anomaly	senderIdentity	10
Suspicious destination	linkDestination	10
Attachment risk	attachmentSafety	8
Request/context mismatch	requestContext	8
Credential disclosure risk	credentialProtection	10
Unsafe MFA request	mfaSafety	8
Sensitive data disclosure risk	sensitiveDataHandling	8
Unauthorized action or access request	authorizationChecks	8
Total		70

These eight knowledge-indicator weights are a new proposed v1 default because the revised knowledge list previously had no complete agreed weight table. They are not universal difficulty rankings. The original screenshot's knowledge weights summed to 93, so its denominator of 83 was inconsistent.

$$K = \text{SUM}(k_i * v0_i) / 70$$

$$PS = 100 * (0.4 * B + 0.6 * K)$$

$$W_{\text{case}} = 0.5 + PS / 100$$

For k, use 0 = no relevant risk evidence, 0.25 = weak cue, 0.50 = moderate concern, 0.75 = strong concern, 1 = explicit high-risk evidence. A link simply existing scores 0 for destination risk. A case with no attachment scores 0 for attachment risk.

Use the complete fixed catalog denominator, including absent indicators as zero. Missing authoring data is not absence: reject it for review. Avoid counting one sender-domain mismatch again as a link anomaly unless a distinct link actually exhibits that problem.

PS range	Descriptive bucket
0 to below 20	Minimal weighted indicators
20 to below 40	Limited weighted indicators
40 to below 60	Moderate weighted indicators
60 to below 80	Strong weighted indicators
80-100	Very strong weighted indicators

PS is not a probability or an answer threshold. A targeted phish can score low; a legitimate urgent request can score high. The retained reward weight favors stronger indicator scores and can undervalue difficult legitimate cases. Pilot this explicitly; changing to a reviewed difficulty weight is a future scoring-version decision.

Score the submission

Only observable responses earn performance credit. Opening panels, taking time, or clicking every option is not evidence of understanding.

$$P = 0.50 * D + 0.30 * E + 0.20 * S$$

Term	Definition	Range
D: decision	Correct approved classification = 1; incorrect = 0. Cases must provide enough evidence or an explicit verification route.	0 or 1
E: evidence	Accuracy of selected relevant evidence, including reassuring evidence in legitimate cases.	0-1
S: safe action	Quality of required verification, handling or reporting decisions.	0-1

$$E = 2 * TP / (2 * TP + FP + FN)$$

$$S = \text{SUM}(r_j * s_j) / \text{SUM}(r_j)$$

TP = relevant evidence selected; FP = unsupported or irrelevant evidence selected; FN = required evidence missed. Evidence units must be defined in the authored rubric. Check-all selections lose precision. Support equivalent valid evidence paths; do not require one arbitrary checklist.

For S, each check s is 0, 0.5 or 1 with authored partial-credit rules. r is its local weight. Critical requirements are evaluated separately. If a component is not applicable or not measurable, omit it and renormalize the remaining coefficients. If no safe-action UI exists: $P = (0.50D + 0.30E) / 0.80$. Never silently grant full credit for an absent component.

Pass gate

G = 1 only if:
 D = 1 AND P >= 0.80 AND all critical checks pass.
 Otherwise G = 0.

P x 100	Feedback
Below 40	Needs explanation
40 to below 60	Partial understanding
60 to below 80	Developing
80 to below 90	Good
90-100	Strong

A critical unsafe action cannot be offset by other points. Inspecting a simulated attachment panel is not itself unsafe execution. State clearly which choices represent real-world risk.

Performance controls passing and supplies skill evidence. In the selected budget-based EXP formula, it is not multiplied into EXP a second time. This supersedes the earlier BaseEXP x difficulty x performance proposal.

EXP without fixed BaseEXP

Allocate the reward budget across planned learning slots, then discount a slot's reward by the successful submission number.

```
T = 1000
Q_phase = T * 0.25 = 250
W_i = 0.5 + PS_i / 100
L_i = Q_phase * W_i / SUM(W_j in phase)
EXP_i = G_i * L_i * A(a_i)
```

T is the course target, Q is the phase budget, W is the case reward weight, L is the learning slot's maximum allocation, and a is the server-counted submission number. There is no fixed per-email BaseEXP. There is also no extra stage or personalized-weight multiplier in v1.

Successful submission	A(a)	Availability
First	1.00	Every phase
Second	0.70	Easy, Normal, Hard
Third	0.40	Easy only
No successful submission	0 EXP	Close after the phase limit and explain

Worked phase allocation

Slot	PS	Weight	Allocation
A	20	0.70	43.75
B	40	0.90	56.25
C	60	1.10	68.75
D	80	1.30	81.25
Total		4.00	250.00

Slot C passes on submission 2: $68.75 \times 0.70 = \mathbf{48.125 \text{ EXP}}$. The remaining 20.625 belongs to that learning slot and is recoverable through fresh targeted assessment, not by replaying the revealed answer.

Allocation rules

Select and approve the phase's cases before computing allocations. Freeze slot budgets; any equivalent replacement inherits its slot allocation. Unselected future phases may adapt as the profile changes. For a mixed-task phase, use weight 1 for non-email slots until their own reviewed challenge model is defined; do not manufacture a PS for a password exercise.

Store precise decimal values. At allocation, use a deterministic remainder rule so the final slot budgets sum exactly to Q. Round only for display. Award once per slot attempt outcome; a repeated request or same-case replay never creates additional rewards.

Personalized tag weights

Personalization changes future practice priority. It does not change whether an email is phishing or retroactively change an offered reward.

```
Ability(u,t) = SUM(q_c,t) / n
Struggle(u,t) = 1 - Ability(u,t)
C(u,t) = n / (n + 5)
W_personal(u,t) = W_base(t) *
[1 + 0.5 * C(u,t) * (2*Struggle(u,t) - 1)]
```

Use up to the latest 10 distinct eligible cases in the same difficulty bucket. q is the first-submission score for that tag. For knowledge, derive q from mapped rubric checks. For the primary behavior tag, q is first-submission P, interpreted as performance in that context rather than causal susceptibility.

For n = 0, initialize the calculation with ability 0.5 and C = 0, but display **Unknown**. C is an evidence-strength factor, not a statistical confidence probability. Exclude answer-revealing tutorials, repeated cases, and pre-answer corrective hints from independent evidence. Access to permitted policies alone does not make an observation ineligible.

Authority example	Player A	Player B
Shared base weight	10	10
Eligible observations	5	5
Ability	0.20	0.80
Struggle	0.80	0.20
C	0.50	0.50
Personalized weight	11.50	8.50

The theoretical multiplier is bounded between 0.5 and 1.5. With this 10-observation window, C never exceeds 2/3, so the effective range is approximately 0.667-1.333. One mistake therefore cannot dominate the profile.

Baseline weights for personalization

Behavior uses the seven values on page 3. For knowledge, use the page-5 weights where a linked PS indicator exists. Use independentVerification = 10, incidentReporting = 8, passwordStrength = 6, passwordUniqueness = 8, dataClassification = 8, sharingPermissions = 8 for the remaining skills. These are proposed coverage-priority defaults, not extra terms in PS.

Sparse data and stronger difficulty

Do not compare Easy success directly with Hard failure. Maintain difficulty-specific evidence. At a new difficulty with no observations, use base weights and required coverage; do not presume either failure or mastery. Corrective retries are recorded as assisted learning outcomes, separately from the independent first response.

Buckets and case selection

Adapt within the company's finite case plan. Required skills and representative legitimate cases remain protected.

Knowledge or behavior score	Profile bucket
Fewer than 3 eligible observations	Insufficient evidence; show count
Below 40	Foundation needed
40 to below 60	Targeted practice needed
60 to below 80	Developing
80 to below 90	Demonstrated
90-100	Strong

Use Score = 100 x Ability. A 3- or 4-case estimate is provisional; even 10 cases is limited evidence. Always retain observation count, difficulty, timestamps and assistance status. Show first-attempt success, eventual success, false alarms and missed phishing separately.

Candidate priority - proposed v1

First filter for approved content, audience eligibility, phase difficulty, remaining required coverage and non-duplicate cases. Then calculate a relative personalization multiplier:

```

R_t = W_personal(t) / W_base(t)
H_g(case) = SUM(x_t * W_base(t) * R_t)
/ SUM(x_t * W_base(t))
Priority(case) = 0.4*H_behavior + 0.6*H_knowledge

```

x is the case's relevant exposure or assessment emphasis: use the primary behavior intensity for behavior and authored assessed-tag emphasis for knowledge. It is not automatically the suspicious-indicator k value. A reporting skill can influence selection even though it does not contribute to PS. If one group is absent, normalize the remaining group to weight 1; if both are absent, route the case to author review.

The ratio preserves the shared baseline while increasing practice priority for genuine gaps. Never substitute personalized weights into PS and present the result as a changed phishing likelihood.

Avoid a repetitive course

Among candidates satisfying the next slot's coverage, use weighted sampling by Priority for 80% of selections and uniform exploration for 20%. Treat this as a configurable starting policy. Use no-repeat checks across campaigns or near-duplicate scenarios, not only exact IDs. A new phase can refresh its candidates; existing slot rewards remain fixed.

No requirement to test every tag repeatedly. A company course may not provide three observations for all skills. Prioritize mandatory objectives and honest uncertainty over extending training to manufacture complete profiles.

Personalization affects case selection first. Adaptive monetary-style rewards are out of scope for v1: otherwise struggling could itself increase future earning opportunities and confuse fair progression.

Recovery and graduation

An EXP target with retry discounts requires a deliberate way to recover missing allocations. Time limits require a defined stopping condition.

```
Remaining(slot) = Allocation(slot) - Earned(slot)
RecoveryEXP = G * Remaining(slot) * A(a)
ProgressPercent = 100 * EarnedTotal / 1000
```

For each deficient slot, present a fresh case assessing equivalent objectives at the same reviewed challenge bucket. It inherits the remaining allocation and the originating phase's attempt limit. First-submission recovery restores the full deficit. Never award more than the slot's original allocation.

Default recovery policy

After the planned cases in a phase, allow one targeted recovery round within the enrollment's recovery allowance. Each deficient slot receives at most one replacement assignment in that round. If deficits remain or the allowance is exhausted, mark Needs follow-up. Preserve all earned EXP. Do not restart the course, silently grant points, or keep generating indefinitely.

Advance to the next phase when its budget and coverage are satisfied. This strict phase-gate choice is part of v1. If the company prefers uninterrupted completion, it needs a separate completion-based progression mode rather than an undocumented exception.

Final-assessment policy

Master slots use unseen cases and one submission each. Graduation requires: **all 1,000 EXP earned, required coverage complete, and critical final-assessment objectives passed**. A failed Master slot can be reassessed once using fresh equivalent content if the recovery allowance permits.

Resolution of an earlier inconsistency: This strict 100%-EXP model supersedes the earlier suggestion that 3 of 4 final cases alone is sufficient. With all Master allocations required, every required final slot must eventually pass, either initially or on its permitted reassessment.

Three useful UI indicators

Indicator	Example
EXP progress	812.5 / 1,000 EXP
Assigned work	16 / 16 planned cases finalized
Outcome	Needs targeted follow-up

Finishing assigned work does not necessarily mean passing. A target duration is the expected planned path plus a stated recovery allowance. A strict time cap, reduced retry rewards and guaranteed 100% graduation cannot all be promised simultaneously.

Server algorithm and data

Every submission and reward transition must be authoritative, persistent and safe to retry after a connection failure.

1. Authenticate employee; check assignment ownership.
2. Lock assignment; look up submission request ID.
3. Return saved response if the request already exists.
4. Confirm open assignment and remaining submissions.
5. Count next attempt on the server; validate answers.
6. Compute D, E, S, P and critical-check result G.
7. Persist response and rubric version.
8. On eligible first submission, add skill evidence.
9. If $G=1$: award slot allocation * A, capped to deficit.
10. Else: give guidance if attempts remain.
11. At limit: close, award 0 and explain.
12. Commit reward, state and observations together.

For an initial assignment, "slot allocation" means its full frozen allocation. For recovery, it means the frozen deficit at recovery assignment creation. Only one open assignment per learning slot is allowed. Feedback must be recorded as viewed before marking a failed practice slot finalized.

Record	Essential fields
Course enrollment	Company, template version, target EXP, phase budgets, coverage, time estimate, recovery policy
Case version	Content, private answer, rubric, ground truth, indicator intensities, knowledge mappings, behavior tags, reviewed difficulty
Learning slot	Phase, objective, decimal EXP allocation, earned amount, coverage status
Assignment	Slot, case version, originating phase, attempt cap, recovery flag, frozen scoring version
Submission	Unique request ID, server attempt number, answers/actions, component scores, pass gate, feedback
Skill observation	Tag, first-submission score, case/difficulty, independence, date, primary behavior if applicable
Reward ledger	Assignment, slot, amount, reason; unique finalized award key

Persist the expected result so an uncertain network retry returns the same response. Refresh resumes the current case with its existing attempt count. Input validation and concurrency protection happen before consuming an attempt. Store answer keys privately and reveal them only at the appropriate feedback stage.

Generation can propose scenarios, labels and rubrics. Only approved versioned cases enter scored play. This PDF specifies intended behavior; it does not verify current code or database implementation.

Worked checks and validation

Use these examples as acceptance criteria before implementing the design or running an employee pilot.

A. Static case Phishing Score

Authority 1.00, Urgency 0.75, Fear 0.50, Familiarity / Impersonation 0.75; other behavior intensities zero. $B = (10 + 7.5 + 4 + 6.75) / 57 = 0.495614$. If $K = 0.80$:

```
PS = 100 * (0.4*0.495614 + 0.6*0.80)
= 67.8246
W_case = 1.178246
```

B. Passing and reward

$D = 1$, $E = 0.80$, $S = 1$ gives $P = 0.94$. All critical checks pass, so $G = 1$. For the 68.75-EXP slot on page 7, passing on submission 2 earns 48.125 EXP. P is not multiplied into that reward again.

C. Recovery and personalization

A fresh first-submission pass recovers 20.625 EXP, restoring the slot to 68.75. The original first-submission gap stays in learning history. A new distinct recovery case can add independent evidence if no answer-revealing hint precedes its first submission.

Check	Required behavior
Duplicate submit / lost response	Same attempt and reward are returned; no double award.
Phase limit	Easy rejects submission 4; Normal/Hard reject 3; Master rejects 2.
Wrong or unsafe answer	No pass even if unrelated rubric points are high.
Unknown tag	Base weight retained; profile displays insufficient evidence.
Mixed case outcomes	False alarms on legitimate emails tracked separately from missed phishing.
Course allocation	Each phase sums to 250; total exactly 1,000 after decimal allocation.
Recovery stopping rule	Unresolved deficits become Needs follow-up, not endless practice.
Replacement case	Inherits frozen slot/deficit budget, preserving total reward.

Pilot measurements

Measure actual session duration including retries; first-pass rates by case and difficulty; false alarms and missed phishing; recovery demand; score changes on fresh cases; and valid alternative answers rejected by the rubric. Review whether PS-weighted allocations systematically under-reward difficult legitimate cases.

Inspect differences by department and language for content mismatch. Low scores from unfamiliar terminology or ambiguous instructions should prompt content correction, not an automatic claim of a skill gap.

Defaults, decisions and references

A compact implementation checklist and a record of what this version intentionally retains or changes.

Setting	Proposed default
Course display target	1,000 EXP
Phase allocation	25% each
Attempt caps	Easy 3; Normal 2; Hard 2; Master 1
Attempt multipliers	1.00; 0.70; 0.40
Static PS blend	40% behavior; 60% knowledge-linked indicators
Behavior denominator	57
Knowledge-indicator denominator	70 (new proposed catalog)
Submission performance	50% decision; 30% evidence; 20% safe action
Pass threshold	$P \geq 0.80$, correct decision, all critical checks
Profile window	Latest 10 eligible distinct cases per tag/difficulty
Personalization strength	$\lambda = 0.5$; $C = n/(n+5)$
Selection blend	40% behavior; 60% knowledge, renormalized if absent
Exploration	20% of eligible selections
Recovery	One bounded round per phase, within course allowance

Decisions that remain subject to validation

The retained PS-based reward policy is a product choice with known limitations. Knowledge-indicator weights, personality-neutral labels, pass thresholds, case counts, exploration share, evidence windows and timing all need pilot testing. A future difficulty-based reward policy requires a new scoring version; do not mix policies inside an active enrollment.

Sources and provenance

The course architecture, weights and formulas are a synthesis of the SENTRI design discussion. They are not supplied or endorsed by NIST. Case detection difficulty should be evaluated independently of indicator count and employee rank.

[1] NIST Phish Scale User Guide, Technical Note 2276 (2023). Discusses human phishing detection difficulty through cues and premise alignment. It does not establish this EXP or personalization formula.
nist.gov/publications/nist-phish-scale-user-guide

[2] NIST SP 800-50 Rev. 1 (2024). Background for cybersecurity and privacy learning programs, role relevance and evaluation.
csrc.nist.gov/pubs/sp/800/50/r1/final